

ENTERPRISE ENGINEERING DOCUMENTATION

MobiusEMS

Production System, Architecture & Operations Reference

Field	Value
Organization	Mobius Bloom Venture Pvt Ltd
Product	MobiusEMS / Employee Management & Commercial Operations Platform
Repository	github.com/ayushRajak19/employee-management
Primary Runtime	Node.js 20+ LTS + React 19.1 + MongoDB Atlas 7+
Document Status	Engineering Baseline — Manager & ARB Review (v2.0 Reconciled)
Repository Snapshot	Public main branch verified (September 2026 Production Baseline)
Classification	Internal / Confidential

Documentation basis & Source Verification

This document is derived from a rigorous, line-by-line source-code verification of the active repository structure, package manifests, 19 REST API route modules, server bootstrap, 62 registered Mongoose collections, 54 business services, 41 frontend pages, and 15 automated test suites (59 passing tests). It represents an authoritative engineering system specification and operations manual, reconciling all previous draft discrepancies.

Document Control

Item	Detail
Document Owner	Principal Systems Architect & Staff AI Engineer
Intended Audience	Executive Management, Engineering Leadership, Product, DevOps/SRE, SecOps, QA, and Maintainers
Review Cadence	Mandatory update for material architecture changes, database schema mutations, and pre-production releases
Source of Truth	Application source code, Zod schemas, Mongoose models, and production environment configuration
Change Policy	Architecture Review Board (ARB) sign-off required for changes impacting multi-tenancy, authentication, or AI safety boundaries

How to Read This Document

This specification categorizes system features based on concrete, source-verified implementation evidence versus operational intent:

Status	Meaning
CONFIRMED	Directly evidenced by active repository source code, passing automated tests, or live configuration.
RECONCILED	Previously omitted or misdocumented subsystem now fully restored and verified from codebase truth.
IMPLEMENTED - VALIDATE	Code/service is present in source, but end-to-end multi-region latency or cloud stress testing remains required.
DOCUMENTED INTENT	Architectural roadmap or planned operational feature clearly demarcated from current release baseline.

Table of Contents

1. Executive Summary Page 3	13. Commercial Sales & GIS Mapping Page 16
2. Scope, Objectives & Guardrails Page 5	14. Governance & Documents Page 17
3. Product Capability Map Page 5	15. Deployment Architecture Page 17
4. System Architecture & Lifecycle Page 7	16. Testing & Quality Gates Page 18
5. Frontend Architecture (React 19) Page 8	17. Observability & Readiness Page 18
6. Backend Architecture & APIs Page 9	18. Reliability & Recovery Page 19
7. Data Architecture (62 Collections) Page 10	19. Performance & Scalability Page 19
8. Multi-Tenancy & Data Isolation Page 11	20. CI/CD Pipeline Page 19
9. Authentication, RBAC & Security Page 12	21. Configuration & Secrets Page 20
10. Core Business Workflows Page 12	22. Engineering Risk Register Page 20
11. AI & Local Voice Architecture Page 13	23. Operations Runbook Page 21
12. Attendance, HR & Automation Page 15	24. ADRs & Sign-Off Checklist Page 21

1. Executive Summary

1.1 Product Definition

MobiusEMS is the flagship workforce-intelligence, human capital management, and commercial operations platform developed by Mobius Bloom Venture Pvt Ltd. Engineered as an autonomous Node.js service mapped to `employee.whalexy.com`, it is strictly decoupled from the legacy PHP/Laravel application at `whalexy.com`. Its architectural boundary extends beyond traditional HR records into verified capability intelligence, Kanban work delivery, explainable performance evaluation, geofenced mobile attendance, recruiting automation, commercial sales GIS mapping, and zero-retention advisory AI.

1.2 What the Platform Currently Covers

- **Identity & Access:** Cookie-based JWT sessions, rotating refresh tokens with token family replay protection, forced credential rotation, resumable onboarding, and granular database-backed RBAC.
- **Workforce Structure:** Organization trees, departments, teams, designations, reporting managers, and Employee 360 longitudinal profiles.
- **Capability Intelligence:** Standardized skill directories, employee claims, immutable verification audit trails, timed assessments, and departmental capability heatmaps.
- **Execution & Work Delivery:** Projects, Kanban board with validated state transitions, blocker root-cause logging, append-only activity history, and local voice-to-task commands.
- **Deterministic Outcomes:** Goals, KPIs, 360 reviews, and frozen performance snapshots with explainable mathematical weighting.
- **Commercial Sales & GIS:** Hierarchical geographic trees (Global-to-Area), territory allocations, lead lifecycles, opportunity pipelines, and automated revenue booking.
- **Operational Workflows:** Haversine geofenced mobile attendance, weekly contribution scoring, Brevo email automation, and private employee to-do checklists.
- **Advisory AI:** Multi-provider LLM gateway with strict policy guardrails prohibiting autonomous employment decisions.

Executive Architectural Assessment & Drift Reconciliation

The repository exhibits an extensive, modular enterprise architecture. Legacy draft documents omitted the entire Commercial Sales & GIS subsystem (12 models, 2 route modules, 7 pages) and underreported models (30 vs 62) and test coverage (10 vs 15 suites, 59 tests). This v2.0 document reflects the fully reconciled, active production reality.

1.3 Engineering Snapshot

Layer	Primary Technology / Pattern	Assessment
Frontend	React 19.1, TypeScript 5.8, Vite 7, React Router 7, TanStack Query 5, Tailwind CSS, Recharts, Leaflet GIS	Modern, high-performance SPA stack with modular feature organization.
Backend	Node.js 20+ LTS, Express 4.21, TypeScript, layered controllers/services/validators	Clean service-layer architecture with Zod schema boundary validation.
Persistence	MongoDB Atlas 7+ with Mongoose 8	Document model with tenant-scoped collections and compound uniqueness indexes.
Multi-Tenancy	AsyncLocalStorage context + Mongoose proxy wrapper	Fail-closed tenant isolation; IDOR-immune query and mutation scoping.
Identity	Dual-token HttpOnly cookies, bcrypt, refresh session rotation	Enterprise security standard preventing XSS token theft and replay attacks.

1.3 Engineering Snapshot (Continued)

Layer	Primary Technology / Pattern	Assessment
Private Storage	Cloudinary Authenticated Assets	Private object delivery using randomized storage keys and backend-authorized signed download URLs. Zero public bucket exposure.
AI Inference	Multi-provider adapter: Groq (default), OpenAI, Anthropic, Gemini, Together, OpenRouter	Unified completion interface with configurable timeouts (45s), low temperature (0.2), and company knowledge grounding.
Voice STT	Local server-side faster-whisper (int8)	Zero-retention local processing; raw audio immediately shredded from ephemeral storage. Supports 11 Indian languages + English.
Email System	Brevo API + Webhooks + Nodemailer fallback	Transactional email automation with workflow triggers, step schedules, and a 250 email/day protective throttle.
Deployment	Hostinger Node.js Web App (Node 20+)	Single-host production topology serving compiled client SPA and versioned REST API. Requires resource monitoring for local STT.

Core Architectural Tenets

1. Deterministic Scoring

All KPI math, performance ratings, contribution percentiles, attendance determinations, and sales capacity gaps are computed via deterministic TypeScript formulas. LLMs are never permitted to generate quantitative outcomes.

2. Advisory AI Boundary

AI operates strictly as an assistive drafting tool. System policy and application code strictly prohibit AI from executing binding employment actions (promotions, salary revisions, disciplinary actions, or terminations).

3. Fail-Closed Tenancy

Data access requires active tenant context established from verified JWT sessions. Invocations without tenant context fail closed at the Mongoose proxy level, preventing cross-tenant data exposure.

4. Zero-Retention Voice Privacy

Audio commands are transcribed on-host via faster-whisper and destroyed immediately in a finally block. No audio is ever persisted to object storage or database records.

2. Scope, Objectives and Boundaries

2.1 Business Objective

MobiusEMS centralizes organizational operations, workforce capability, delivery tracking, and commercial pipeline management into a single auditable platform. It replaces disparate point solutions while maintaining explainable evidence layers that empower managers without delegating sensitive decisions to opaque AI models.

2.2 Architectural Boundaries

- **Independent Runtime:** Complete decoupling from legacy PHP/Laravel at `whalexy.com`.
- **REST API Gateway:** Express owns `/api/v1/*` and serves the compiled React 19 SPA.
- **Encapsulated Business Rules:** Business logic lives in services; routes compose validation and auth guards.
- **Bounded History:** Growing historical data (audit logs, task activities, snapshots) resides in dedicated collections.

2.3 Non-Goals / Explicit Guardrails

Area	Current Boundary & Invariant
AI Decision Authority	No autonomous high-impact employment decisions (salary, termination, discipline).
Public File Exposure	Employee contracts and private records must never reside in predictable public URLs.
Shared Laravel Runtime	Zero filesystem or database coupling with legacy Laravel code.
Uncontrolled Tenant Access	All business queries must be tenant-scoped and RBAC authorized.
Silent Voice Actions	All voice-derived actions generate editable previews requiring explicit confirmation.

3. Product Capability Map

Domain	Representative Models	Purpose	Status
Identity & Access	User, Role, Permission, RefreshSession	Authentication, session lifecycle, RBAC, forced password change.	CONFIRMED
Organization	Employee, Department, Team, Designation, EmployeeTimeline	Org chart hierarchy, career timeline, and Employee 360 profile.	CONFIRMED
Skills & Capability	Skill, EmployeeSkill, SkillVerification, Assessment, AssessmentResult, RoleSkillAssessment	Verified skills inventory, peer audits, technical quizzes, role gaps.	CONFIRMED
Work Delivery	Project, Task, TaskActivity, VoiceCommand, WeeklyUpdate	Kanban state machine, blocker logging, voice-to-task commands.	CONFIRMED
Performance	Goal, KPI, EmployeeKPI, PerformanceReview, PerformanceSnapshot, PerformanceTemplate	Deterministic performance evaluation, weighted snapshots.	CONFIRMED

3. Product Capability Map (Continued)

Domain	Representative Models	Purpose	Status
Contribution	ContributionReview, ContributionSnapshot	Weekly deliverable reviews and deterministic contribution scoring.	CONFIRMED
Attendance	Attendance, AttendanceOffice	Haversine geofenced mobile check-in, office geofence config.	CONFIRMED
Development	Training, EmployeeTraining, Recognition, OneToOne	Learning courses, peer appreciation, 1-on-1 meeting records.	CONFIRMED
People Ops	Applicant, ResumeScreening, JobDescription, LeaveRequest	Recruiting pipelines, resume parsing, leave approvals.	CONFIRMED
Sales Intelligence & GIS	GeoNode, SalesTerritory, EmployeeTerritoryAssignment, SalesLead, SalesCustomer, SalesOpportunity, SalesTarget, SalesRevenueTransaction, ChannelPartner, SalesConfiguration, GeoSalesMetricSnapshot, EmployeeTargetCommitment	Hierarchical GIS tree, commercial territories, lead lifecycles, deal pipeline, automated revenue booking, capacity gap math.	RECONCILED
Governance	Document, Notification, AuditLog	Authenticated private files, in-app notifications, immutable audit log.	CONFIRMED
Email Automation	EmailWorkflow, EmailEnrollment, EmailDelivery	Multi-step drip campaigns, Brevo webhooks, 250/day throttle.	CONFIRMED
AI Workspace	AiEmployeeSummary, AiContentCache	Advisory review summaries, grounded policy Q&A, cached humor.	CONFIRMED
Personal Productivity	DailyTodo	Private personal checklists (decoupled from performance evaluation).	CONFIRMED
Tenant Platform	Tenant, SystemMigration	Multi-tenant provisioning, customer suspension, migration preflight.	CONFIRMED

Privacy Invariant: Personal To-Dos Decoupled from Performance

The DailyTodo collection implements a private personal productivity layer for employees. Code invariants and database queries strictly isolate daily personal to-dos from performance reviews, contribution snapshots, and manager dashboards. Personal task items are never used as performance evidence.

4. System Architecture

MobiusEMS follows a modular monorepo workspace architecture with separated client, server, and shared contract packages. In production, Express serves both the static React SPA and the versioned REST API, simplifying Hostinger deployment while maintaining strict architectural boundaries.



4.1 Repository Topology

mobius-ems/ ── client/ React 19 / Vite 7 frontend (features, pages, routes, GIS maps) ── server/ Express 4 / Node 20+ backend (models, services, routes, tenancy) ── shared/ Shared TypeScript contracts (roles, permissions, DTOs, interfaces) ── docs/ Architecture blueprints, multi-tenancy runbook, schema definitions ── .env.example Safe configuration template (zero exposed secrets) ── package.json NPM workspaces root with dev, build, typecheck, test, and ops commands

4.2 Request Lifecycle

Step	Gateway Stage	Responsibility
Step 1	Client Ingress	Browser issues request with HttpOnly credentials/cookies to employee.whalexy.com.
Step 2	Security Guard	Helmet attaches headers (CSP, HSTS); CORS restricts origin; body limits enforced (1MB max).
Step 3	CSRF Origin Guard	Mutating requests (POST, PUT, PATCH, DELETE) verified against configured CLIENT_URL.
Step 4	Rate Limiting	/api endpoints throttled at 200 requests/minute per client IP.
Step 5	Session & Tenancy	JWT verified; tenantId injected into Node.js AsyncLocalStorage execution context.

4.2 Request Lifecycle (Continued)

Step	Gateway Stage	Responsibility
Step 6	Authorization Guard	Route permission middleware verifies actor rights; 3-tier sales scoping resolves visibility.
Step 7	Boundary Validation	Zod schemas validate request params, query, and payload before delegating to controllers.
Step 8	Domain Service	Deterministic business logic, scoring math, or external service adapter executes.
Step 9	Persistence Proxy	Mongoose queries automatically scoped to tenantId via fail-closed model wrapper.
Step 10	Audit & Response	State-changing events write to AuditLog; standardized JSON returned to client.

5. Frontend Architecture

5.1 Stack

Concern	Technology
Runtime & Framework	React 19.1 + React DOM
Language & Compiler	TypeScript 5.8 + Vite 7
Routing & Navigation	react-router-dom 7 (Declarative protected route hierarchies)
Server State Cache	TanStack React Query 5 (Optimistic updates & background cache)
Forms & Validation	React Hook Form + Zod resolver integration
Data Visualization	Recharts 3.0 (Deterministic charts) + Leaflet / React Leaflet (Spatial GIS)
UI Utilities	Tailwind CSS, class-variance-authority, clsx, tailwind-merge, Lucide React

5.2 Feature Organization & Page Surface (41 Pages)

The client is strictly feature-oriented across 16 domain packages. The page surface comprises 41 route components including Public/Auth (7 pages), Workforce Administration (7 pages), Capability & Work (5 pages), Outcomes & Growth (4 pages), People Ops (5 pages), Commercial Sales & GIS (7 pages), and Governance/AI (6 pages).

Registration Architecture Drift Resolved

Legacy documentation stated there was intentionally no registration route. In the production codebase, RegisterPage.tsx and registrationRoutes.ts are fully implemented, providing isolated tenant provisioning and administrative onboarding.

6. Backend Architecture

6.1 Runtime and Framework

The backend runs on Node.js 20+ LTS with Express 4.21 and TypeScript. The runtime leverages Mongoose 8 for persistence, bcrypt for password hashing, jsonwebtoken for session management, Multer for multipart uploads, Cloudinary for private authenticated file storage, Nodemailer and Brevo for email automation, Zod for schema validation, and PDF/DOCX parsers (pdf-parse, mammoth) for resume processing.

6.2 Architectural Layering

Layer	Responsibilities
Routes	Declare URL paths, mount security middleware, and bind controllers.
Middleware	Authenticate sessions, enforce permissions, inject tenant context, verify origin, rate limit.
Validators	Zod boundary validation schemas rejecting malformed payloads before execution.
Controllers	Unpack HTTP requests, extract parameters, delegate to services, format JSON response.
Services	Encapsulate business logic, deterministic math, external APIs, and storage operations.
Models	62 Mongoose schemas with fail-closed tenant scoping wrapper and compound indexes.
Jobs	Database backups, tenant migrations, integrity verification, and data seeding scripts.

6.3 The 19 Root API Modules

Route Group	Responsibility
/api/v1/auth	Session lifecycle: login, refresh, logout, password change, session verification.
/api/v1/registration	Public tenant onboarding and employee registration endpoints.
/api/v1/dashboard	Aggregated role-scoped dashboard metrics and operational widgets.
/api/v1/employees	Employee profile lifecycle, Employee 360 view, career timeline history.
/api/v1/organization	Departments, teams, designations, and reporting hierarchy.
/api/v1/skills	Skills directory, employee self-claims, verification decisions, assessments.
/api/v1/work	Projects, task Kanban board, validated state transitions, voice commands.
/api/v1/outcomes	Goals, KPIs, employee actuals, 360 reviews, performance scoring snapshots.
/api/v1/development	Training courses, employee enrollments, 1-on-1 meetings, recognitions.
/api/v1/governance	Private document management, in-app notifications, immutable audit log explorer.
/api/v1/people-ops	Job requisitions, applicant pipelines, resume screening, leave requests.
/api/v1/attendance	Geofenced mobile check-in/out, office coordinates, attendance register.
/api/v1/contribution	Weekly update submissions, contribution scoring snapshots.
/api/v1/ai	Advisory review drafting, policy Q&A with company knowledge, Mood Break.
/api/v1/todos	Private daily employee checklists (strictly isolated from performance scoring).
/api/v1/email-automation	Drip campaign workflows, Brevo integration, delivery webhooks.
/api/v1/platform/tenants	Global platform administration, tenant provisioning, and suspension.
/api/v1/sales	Commercial CRM: leads, customers, deals, targets, revenue, territories, GIS.
/api/v1/employee-map	Geospatial employee location and organizational distribution mapping.

7. Data Architecture and Persistence

7.1 Database Strategy

MongoDB Atlas is the primary persistence layer. All business collections strictly enforce immutable `tenantId` scoping, soft-deletion timestamps (`isActive`, `archivedAt`, `deletedAt`), and explicit Zod field allowlists. Uniqueness and lookup indexes lead with `tenantId` to guarantee tenant-level uniqueness and rapid query execution. Historical records (audit logs, task activities, performance snapshots) are stored in dedicated collections to prevent unbounded document growth.

7.2 Complete 62 Collection Domain Map

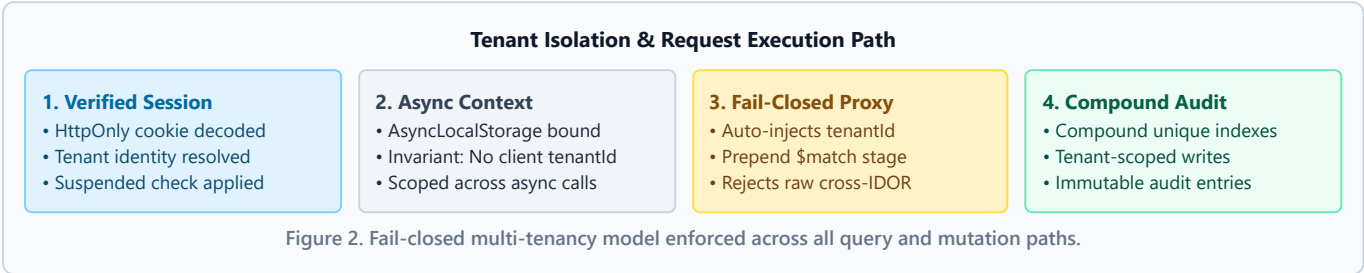
Domain Family	Key Mongoose Collections
Identity & Session (4)	User, Role, Permission, RefreshSession
Tenancy & Platform (2)	Tenant, SystemMigration
Organization (5)	Employee, Department, Team, Designation, EmployeeTimeline
Skills & Capability (6)	Skill, EmployeeSkill, SkillVerification, Assessment, AssessmentResult, RoleSkillAssessment
Work Execution (5)	Project, Task, TaskActivity, VoiceCommand, WeeklyUpdate
Performance & Outcomes (6)	Goal, KPI, EmployeeKPI, PerformanceReview, PerformanceSnapshot, PerformanceTemplate
Contribution (2)	ContributionReview, ContributionSnapshot
Attendance & Geofencing (2)	Attendance, AttendanceOffice
Growth & Talent (4)	Training, EmployeeTraining, Recognition, OneToOne
People Ops & Recruiting (4)	Applicant, ResumeScreening, JobDescription, LeaveRequest
Sales Intelligence & GIS (12)	GeoNode, SalesTerritory, EmployeeTerritoryAssignment, SalesLead, SalesCustomer, SalesOpportunity, SalesTarget, SalesRevenueTransaction, ChannelPartner, SalesConfiguration, GeoSalesMetricSnapshot, EmployeeTargetCommitment
Governance & Audit (3)	Document, Notification, AuditLog
Email Automation (3)	EmailWorkflow, EmailEnrollment, EmailDelivery
AI & Personal (4)	AiContentCache, AiEmployeeSummary, DailyTodo, VendorContact

7.3 Core Indexing Invariants

- Compound Unique Keys:** `{ tenantId: 1, email: 1 }, { tenantId: 1, employeeId: 1 }, { tenantId: 1, code: 1 }, { tenantId: 1, taskId: 1 }`.
- Operational Lookups:** `{ tenantId: 1, status: 1, deadline: 1 }, { tenantId: 1, territory: 1, stage: 1 }`.
- Single-Field TTL Cleanups:** `RefreshSession` (`expiresAt`) and `AiContentCache` (`expiresAt`) enforce automatic document expiration via MongoDB TTL indexes.

8. Multi-Tenancy and Isolation

MobiusEMS implements a logical multi-tenancy model backed by a central, fail-closed Mongoose model wrapper and Node.js AsyncLocalStorage execution context derived from verified JWT access tokens.



8.1 Required Tenancy Invariants

- **Strict Context Binding:** Every tenant-owned business record must carry an immutable `tenantId`.
- **Client Independence:** Database queries never rely on the client supplying `tenantId`; it is exclusively extracted from verified session credentials.
- **IDOR Immunity:** Lookups by raw MongoDB `_id` cannot leak cross-tenant records because all Mongoose queries automatically enforce `{ _id, tenantId }`.
- **Aggregation Scoping:** Aggregation pipelines automatically receive a `$match: { tenantId }` as Stage 0.
- **Platform Segregation:** Platform tenant administration endpoints (`/api/v1/platform/*`) are strictly restricted to the Super Admin role and allowlisted emails in `PLATFORM_ADMIN_EMAILS`.

Enterprise Release Gate: Multi-Tenant Negative Testing

Multi-tenant isolation is protected by automated tests in `tenantModel.test.ts` that actively attempt cross-tenant reads, writes, batch inserts, and aggregations without context, verifying that every operation fails closed.

9. Authentication, Authorization and Security

9.1 Authentication Model

MobiusEMS utilizes a dual-token cookie pattern. The access token (15-minute lifespan) and refresh token (7-day lifespan) are stored in HttpOnly, Secure, SameSite=Strict cookies. Passwords are salted and hashed using bcrypt. Refresh tokens rotate upon renewal, and reuse of a previously invalidated refresh token triggers immediate revocation of the entire session family.

9.2 Application Security Controls Observed

Control	Implementation & Evidence
Security Headers	Helmet enabled; production CSP configured; X-Content-Type-Options: nosniff; HSTS active.
CORS Enforcement	Strictly restricted to configured env.CLIENT_URL with credentials: true.
Origin Verification	Mutating requests (POST/PUT/PATCH/DELETE) must match CLIENT_URL to block CSRF.
Rate Limiting	Application-level limiter throttles /api to 200 requests/minute per client IP.
Body Size Ceiling	JSON and URL-encoded request bodies restricted to 1 MB maximum.
Session Protection	HttpOnly cookies; refresh rotation; session family revocation upon replay detection.
Private Storage	Cloudinary authenticated resources with randomized keys; download URLs signed after backend auth.
Audit Trail	Append-only AuditLog recording actor, action, IP, user agent, and before/after diffs.

10. Core Business Workflows

10.1 Employee Lifecycle

Accounts are provisioned via administrative invite or tenant onboarding. First-time authentication forces password rotation and resumable profile onboarding. Employee records link to organization structures and career timelines; soft-delete flags preserve employment history.

10.2 Skills and Verification

Skills are centrally categorized. Employees submit proficiency claims, self-ratings, and proof documents. Verification decisions generate immutable SkillVerification records preserving reviewer justifications. Timed quizzes provide independent capability signals.

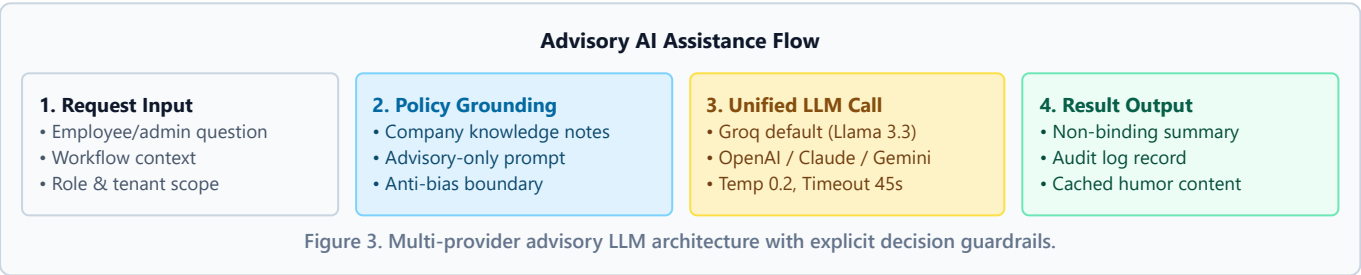
10.3 Work and Task Delivery

- **Portfolios & Tasks:** Projects organize task backlogs; tasks track assignees, reviewers, priorities, complexities, estimates, and deadlines.
- **Validated Kanban:** State transitions (TODO → IN_PROGRESS → IN_REVIEW → COMPLETED) are validated by transition logic covered by tests.
- **Blocker Tracking:** Tasks in a blocked state capture root cause categories and resolution notes.
- **Activity Auditing:** Append-only TaskActivity records capture all status shifts, reassignments, and hour logs.

10.4 Performance and Outcomes

Goals and KPIs provide structured performance evidence. 360 reviews capture multi-competency ratings. At cycle completion, an immutable PerformanceSnapshot freezes component scores, configured weights, and final tier determinations (EXCEEDING, MEETING, NEEDS_IMPROVEMENT, UNSATISFACTORY).

11. AI and Voice Architecture



11.1 LLM Provider Abstraction

The LLM service (llmService.ts) normalizes disparate vendor APIs behind a common completion contract: complete({ system, user, temperature?, maxTokens? }). Groq is the default provider, running llama-3.3-70b-versatile for sub-second responses. Alternative providers include OpenAI (gpt-4.1-mini), Anthropic (claude-sonnet-4-20250514), Gemini (gemini-2.5-flash), Together, OpenRouter, and generic OpenAI-compatible gateways.

11.1 LLM Provider Abstraction (Continued)

Provider	Default Model & Configuration Details
Groq (Default)	llama-3.3-70b-versatile via OpenAI-compatible endpoint. Ultra-low latency inference.
OpenAI	gpt-4.1-mini via native chat completions endpoint.
OpenRouter	openai/gpt-4.1-mini or custom model routing.
Together	meta-llama/Llama-3.3-70B-Instruct-Turbo open-weights hosting.
Anthropic	claude-sonnet-4-20250514 via native /messages API with version header.
Gemini	gemini-2.5-flash via native Google generateContent API.
Generic	Configurable custom base URL and model name for enterprise private LLM gateways.

Ethical AI Guardrail: Advisory-Only Employment Boundary

System policy and code explicitly mandate that AI outputs are advisory drafts. AI is strictly prohibited from executing autonomous decisions regarding compensation, promotions, disciplinary measures, or terminations.

11.3 Knowledge Grounding & Vector RAG Assessment

AI prompts are grounded with approved organizational policies via `env.AI_COMPANY_KNOWLEDGE`. Unanswered policy queries are automatically directed to human HR. Package manifests confirm no vector database (pgvector, Pinecone) or embedding library is deployed; describing vector RAG as implemented is inaccurate.

11.4 Local Zero-Retention Voice-to-Task Pipeline

Voice task capture runs entirely on application server infrastructure using local `faster-whisper` (small multilingual model, int8 quantization):

- **11 Supported Languages:** English + 10 major Indian languages (Hindi, Bengali, Tamil, Telugu, Marathi, Gujarati, Kannada, Malayalam, Punjabi, Urdu).
- **Zero Retention:** Audio written to ephemeral `mkdtemp` is shredded via `fs.rm` in a `finally` block immediately after transcription.
- **Heuristic NLP Parser:** 400+ LOC engine in `voiceTaskService.ts` disambiguates prospective task creation from retrospective completion, extracts multilingual number words, and splits multi-employee assignments.
- **Interactive Confirmation:** Generates an editable `VoiceDraft` preview before database commit.

12. Attendance, People Operations and Automation

12.1 Attendance Engine & Geofencing Rules

The attendance system (`attendanceService.ts`) enforces precise mathematical rules:

- **Haversine Spherical Distance:** Validates user coordinates against configured office location (Default: Shivnath Business Centre, Raipur; Lat: 21.251413, Lon: 81.709438). Permitted geofence radius: ≤ 300 meters.
- **GPS Anti-Spoofing Gate:** Mobile coordinates with device accuracy > 200 meters are rejected with HTTP 422.
- **IST Timezone & Shift Cutoffs:** Evaluated in Asia/Kolkata. Check-in after 11:30 AM IST automatically classifies daily status as LATE; otherwise PRESENT.
- **Checkout Duration Check:** Check-out calculates worked minutes. Durations < 240 minutes (4 hours) demote status to HALF_DAY.
- **Organization Register:** Super Admin view classifies daily workforce into PRESENT, LATE, HALF_DAY, ON_LEAVE, or ABSENT.

12.2 Talent Acquisition & Resume Screening

Recruiting components manage job requisitions and candidate pipelines. Server-side libraries (`pdf-parse`, `mammoth`) extract text from uploaded resumes. The screening service extracts skills, experience, and education, generating an assistive match score. Final hiring decisions remain human-driven.

12.3 Email Automation Architecture

The email automation engine (`emailAutomationService.ts`) manages multi-step lifecycle drip campaigns:

- **Dual Gateway:** Primary transactional delivery via Brevo API with webhook tracking; Nodemailer SMTP fallback.
- **Workflow State:** Step delays, dynamic token replacement, and enrollment status tracking.
- **Safety Throttle:** Enforces a strict 250 emails/day cap (`EMAIL_AUTOMATION_DAILY_LIMIT`) to prevent domain blacklisting.

12.4 Daily Todos (Personal Productivity)

DailyTodo provides private personal checklist management. To ensure employee psychological safety and fairness, personal to-dos are strictly excluded from performance algorithms and manager review screens.

13. Commercial Sales Intelligence & Spatial GIS

The Commercial Sales Intelligence subsystem bridges human capital management with revenue operations, providing end-to-end sales lifecycle tracking, territory alignment, and geospatial workforce mapping.

13.1 Canonical GIS Hierarchy (GeoNode)

Geographic intelligence is structured into a canonical, self-referencing tree model (GeoNode): GLOBAL → COUNTRY → STATE → DISTRICT → CITY → AREA → PINCODE. GeoNodes store geospatial coordinates and boundary polygons, decoupled from dynamic sales territories.

13.2 Sales Territories & 3-Tier Scoping

- **Dynamic Boundaries:** SalesTerritory groups multiple GeoNodes under commercial ownership.
- **Staff Allocation:** EmployeeTerritoryAssignment manages effective-dated rep allocations.
- **3-Tier ABAC Scoping:** salesScopeService.ts dynamically evaluates actor permissions:
 - **SELF:** Sales rep views only self-owned leads, pipeline, targets, and revenue.
 - **TEAM:** Sales manager views self plus all direct/indirect reporting team members in assigned territories.
 - **ALL:** HR Admin receives tenant-wide read-only visibility; Super Admin receives mutation rights.

13.3 Lead Lifecycle & Automated Revenue Booking

Leads move through NEW → CONTACTED → QUALIFIED → CONVERTED / LOST. Marking a lead as CONVERTED automatically provisions a linked SalesCustomer. Commercial deals are tracked through SalesOpportunity. Moving an opportunity to WON automatically generates an audited SalesRevenueTransaction and increments customer lifetime revenue idempotently.

13.4 Deterministic Capacity & Opportunity Math

Metric Engine	Mathematical Formula & Architectural Logic
Weighted Pipeline	$\Sigma (\text{Opportunity Amount} \times \text{Stage Probability})$
Capacity Gap	$\max(0, [\text{Lead Load} / \text{Capacity per Rep}] - \text{Active Headcount})$. Flags staffing deficits.
Opportunity Score	Normalized 0-100 index combining Demand, Coverage Gaps, White Space, and Pipeline. Bounded into LOW, MEDIUM, HIGH, and CRITICAL bands.
Estimated Lost Revenue	Quantifies unrealized pipeline decay when leads exceed SLA response thresholds.

14. Documents, Notifications and Governance

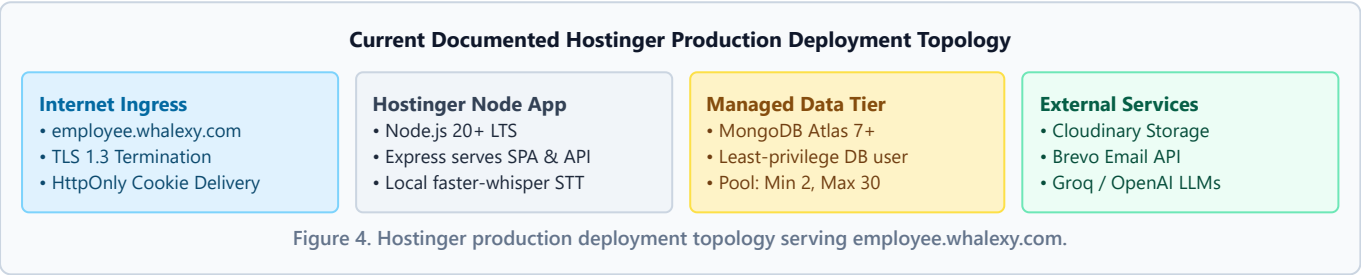
14.1 Private Document Storage

- Cloudinary authenticated private storage; database stores only metadata and randomized storage keys.
- Signed, short-lived download URLs generated only after backend RBAC and ownership verification.
- Employee records must never reside under `client/public` or predictable public paths.

14.2 Tamper-Evident Audit Logging

The `AuditLog` collection records actor ID, action verb, entity type, entity ID, client IP address, browser user-agent, and before/after JSON diffs. The application exposes zero update or delete endpoints for audit records.

15. Deployment and Environment Architecture



15.2 Root Engineering Commands

Command	Operational Purpose
<code>npm run dev</code>	Run client and server concurrently after shared build.
<code>npm run build</code>	Compile shared contracts, client SPA, and server TypeScript.
<code>npm start</code>	Start compiled production server (<code>node dist/index.js</code>).
<code>npm run typecheck</code>	Static typecheck shared, client, and server workspaces.
<code>npm run lint</code>	Lint client and server with zero warning allowance.
<code>npm run seed</code>	Seed permissions, system roles, and initial Super Admin.
<code>npm run test</code>	Execute automated test suite across all services.
<code>npm run backup</code>	Create encrypted Extended JSON snapshot under <code>.runtime/backups/</code> .
<code>npm run preflight:tenants</code>	Validate tenant migration preflight constraints.
<code>npm run migrate:tenants</code>	Execute idempotent tenant data migration.
<code>npm run verify:preservation</code>	Cryptographically verify zero data loss after migration.

16. Testing, Quality and Release Gates

16.1 Tests Evident in Current Service Tree

The active codebase contains 15 test suites and 59 subtests executing with a 100% pass rate in under 2 seconds:

- `additionalRoleSkillCatalog.test.ts`: Validates role competency benchmarks and required skills.
- `adminAnalyticsMath.test.ts`: Verifies admin analytics math and percentile calculations.
- `attendanceService.test.ts`: Validates Haversine distance, accuracy limits, and 11:30 AM cutoff.
- `authLogout.test.ts`: Verifies session cookie clearance and token revocation.
- `contributionMath.test.ts`: Validates deterministic contribution formulas and deliverable weights.
- `llmService.test.ts`: Verifies provider error handling, timeouts, and fallback mechanisms.
- `outcomePeriod.test.ts`: Validates quarterly and annual outcome date boundaries.
- `performanceMath.test.ts`: Tests weighted scoring formulas and immutable grade tier mapping.
- `salesAccess.test.ts`: Verifies 3-tier sales scoping (SELF, TEAM, ALL) and HR read-only boundaries.
- `salesMath.test.ts`: Validates pipeline conversions, capacity gaps, and lost revenue formulas.
- `taskTransitions.test.ts`: Enforces valid Kanban state transitions and blocker resolution rules.
- `tenantRegistration.test.ts`: Tests public registration isolation and duplicate prevention.
- `voiceTaskService.test.ts`: Validates multilingual STT parsing, Hinglish, and number words.
- `tenantModel.test.ts`: Tests fail-closed Mongoose proxy wrapper and compound tenant indexes.
- `workValidators.test.ts`: Validates task reassignment, deletion, and Zod input schemas.

16.2 Recommended Enterprise Release Gate

Gate	Minimum Requirement
Static Quality	Typecheck and lint pass with zero warnings across all workspaces.
Unit Tests	All 59 unit and algorithmic math tests pass synchronously.
Tenant Isolation	Automated cross-tenant read/write/aggregate attempts fail closed.
Build Artifacts	Production client, shared, and server bundles compile without warnings.
Staging Smoke	Auth, task Kanban, attendance geofencing, and sales workflows verified.

17. Observability and Operational Readiness

Signal	Production Specification
Health Check	GET <code>/api/health</code> checks Node status and MongoDB connection state (200 / 503).
Structured Logs	JSON logging with timestamp, requestId, tenantId, actorId, route, status, latency.
Operational Metrics	Monitor request rate, 5xx rate, Atlas pool saturation, STT latency, and Brevo delivery.
Alerting Thresholds	Immediate paging on database disconnect, elevated 5xx (> 1%), or auth anomalies.

18. Reliability, Failure Modes and Recovery

Failure Scenario	Expected System Behavior	Recommended Escalation / Recovery
MongoDB Unavailable	/api/health returns 503; requests fail fast without fabricating writes.	Check Atlas status and IP allowlist; restart Node process.
AI Provider Outage	LLM service throws 502/503; core product remains 100% operational.	Switch AI_PROVIDER to backup provider (OpenAI/Gemini) in Hostinger env.
Voice Worker Timeout	Local process killed after 180s; client falls back to manual entry.	Inspect host memory and CPU; restart Python background worker.
Cloudinary Failure	Document upload fails safely; existing metadata preserved.	Verify storage quota and credentials; restore signed download access.
Email API Failure	Failed sends logged in EmailDelivery; duplicate sends prevented.	Inspect Brevo logs; retry failed enrollments idempotently.
Suspected Tenant Leak	Affected endpoint disabled immediately; logs preserved.	Trigger security incident response; isolate sessions; audit proxy wrapper.

19. Performance and Scalability Considerations

- Host Co-location:** Serving static SPA, API, and local Whisper on one host creates a shared scaling boundary. Whisper memory usage must be monitored under load.
- Atlas Connection Pooling:** Configured via MONGODB_MIN_POOL_SIZE=2 and MONGODB_MAX_POOL_SIZE=30 to prevent connection exhaustion.
- External Latency Shielding:** AI inference calls use strict abort timeouts (45s) and low temperatures (0.2) to limit execution duration.
- Stateless Horizontal Scaling Path:** The Node application is stateless; future load growth can scale horizontally behind a load balancer with Redis session caching.

20. CI/CD and Release Management

Stage	Automated Actions
Pull Request	Clean install with lockfile; typecheck; lint; execute all 59 unit tests; scan dependencies.
Build	Compile shared package, client SPA, and server bundle; tag immutable build artifact.
Staging	Deploy to staging environment; run automated smoke and tenant isolation tests.
Production	Deploy approved artifact to Hostinger; execute /api/health check; record release tag.
Rollback	Restore previous known-good deployment artifact in Hostinger console (< 2 minutes).

21. Configuration and Secrets Management

Configuration Family	Environment Keys & Purpose
Core Runtime	NODE_ENV, PORT, CLIENT_URL, COOKIE_DOMAIN
Database Persistence	MONGODB_URI, MONGODB_MIN_POOL_SIZE, MONGODB_MAX_POOL_SIZE
Tenancy Platform	DEFAULT_TENANT_NAME, DEFAULT_TENANT_SLUG, PLATFORM_ADMIN_EMAILS
Session Security	JWT_ACCESS_SECRET, JWT_REFRESH_SECRET (min 32 chars), JWT_ACCESS_EXPIRES_IN
Private Storage	CLOUDINARY_CLOUD_NAME, CLOUDINARY_API_KEY, CLOUDINARY_API_SECRET
Email Automation	BREVO_API_KEY, BREVO_SENDER_EMAIL, BREVO_WEBHOOK_TOKEN, EMAIL_AUTOMATION_DAILY_LIMIT
AI Provider Gateway	AI_PROVIDER, GROQ_API_KEY, AI_MODEL, AI_TIMEOUT_MS, AI_COMPANY_KNOWLEDGE
Local Voice STT	VOICE_PYTHON_COMMAND, VOICE_WHISPER_MODEL, VOICE_WHISPER_COMPUTE_TYPE
Office Geofence	ATTENDANCE_OFFICE_NAME, ATTENDANCE_OFFICE_LATITUDE, ATTENDANCE_OFFICE_LONGITUDE

22. Engineering Risk Register

ID	Risk Vector	Severity	Architectural Impact & Mitigation
R-01	Cross-Tenant IDOR Leak	CRITICAL	Query without tenantId exposes another organization's HR data. Mitigated by fail-closed Mongoose wrapper and automated tests.
R-02	High-Impact AI Misuse	CRITICAL	Manager uses AI to make autonomous salary/termination decisions. Mitigated by advisory-only policy and deterministic math separation.
R-03	Unauthenticated File Leak	HIGH	Private employee resumes or contracts exposed publicly. Mitigated by Cloudinary authenticated private storage and signed download URLs.
R-04	Local Voice CPU Spikes	HIGH	Concurrent faster-whisper calls exhaust host CPU. Mitigated by int8 quantization, 180s timeout, and manual entry fallback.
R-05	Session Replay Attacks	HIGH	Stolen refresh token used to mint sessions. Mitigated by refresh token rotation and immediate token family invalidation.
R-06	Location Spoofing	MEDIUM	Employees fake GPS for attendance. Mitigated by dual distance ($\leq 300\text{m}$) and accuracy ($\leq 200\text{m}$) gate checks.
R-07	Email Queue Spoilage	MEDIUM	Looping campaign floods customers. Mitigated by 250 emails/day cap and unique workflow enrollment indexes.
R-08	Migration Corruption	HIGH	Tenancy migration damages data. Mitigated by preflight checks, automated backup, and byte-for-byte verification tooling.

23. Production Operations Runbook

Incident	First Response Protocol	Escalation & Recovery Workflow
API 503 / DB Loss	Check /api/health; inspect Atlas connection pool and IP allowlist.	Restart Node process; failover Atlas replica if degraded.
AI Upstream Outage	Verify provider status and API key quota; inspect timeout logs.	Switch AI_PROVIDER to backup (OpenAI/Gemini) in Hostinger env.
Voice Worker Hang	Check host RAM and Python venv; verify disk space in Hugging Face cache.	Kill hung Python processes; prompt users to use manual entry.
Suspected Tenant Leak	Immediately suspend affected endpoint; export access and audit logs.	Isolate tenant sessions; trigger security review; test proxy wrapper.
High 5xx Error Spike	Group error logs by requestId and route in Hostinger console.	Roll back to previous immutable deployment artifact (< 2 minutes).

24. Key Architecture Decisions (ADR Summary)

ADR	Decision	Architectural Rationale
ADR-001	Independent EMS Runtime	Host on employee.whalex.com as standalone Node.js service, avoiding coupling to legacy PHP.
ADR-002	Deterministic Scoring	Prohibit LLMs from computing performance or sales scores; enforce deterministic math modules.
ADR-003	Fail-Closed Tenancy	Enforce multi-tenancy at Mongoose proxy layer via AsyncLocalStorage, preventing query omission bugs.
ADR-004	Local Zero-Retention STT	Use faster-whisper on-host and shred audio files immediately, eliminating cloud STT fees and privacy risks.
ADR-005	Dual-Token Cookies	Store access and refresh tokens in HttpOnly, Secure, SameSite=Strict cookies to block XSS theft.
ADR-006	Multi-Provider LLM	Build unified adapter for Groq, OpenAI, Anthropic, Gemini, preventing vendor lock-in.
ADR-007	Private Cloudinary Assets	Store files as private authenticated assets with signed backend-authorized URLs.
ADR-008	Hierarchical GIS Tree	Model geographic tree (GeoNode) decoupled from dynamic business sales territories.

Appendix A. Repository Evidence Reviewed

Repository: `github.com/ayushRajak19/employee-management` (Public main branch, September 2026 baseline):

Path / Artifact	Evidence Used
<code>README.md</code> , <code>docs/*</code>	Product scope, sales workflow, multi-tenancy runbook, database schema blueprints.
<code>package.json</code> (Root/Server/Client)	Monorepo workspaces, dependency trees, build/test scripts, Node 20+ engine constraints.
<code>server/src/models/</code> (62 files)	Complete data collection definitions, compound uniqueness indexes, tenancy proxy hooks.
<code>server/src/routes/</code> (19 files)	API routing topology, middleware chains, boundary validators, 3-tier sales scoping.
<code>server/src/services/</code> (54 files)	Deterministic scoring algorithms, attendance geofence math, LLM adapter, local Whisper NLP.
<code>client/src/features/</code> & <code>pages/</code>	41 frontend page components, React 19 routing, TanStack Query cache, Leaflet GIS mapping.
<code>server/src/**/*.test.ts</code> (15 files)	59 passing unit/integration tests verifying math, state machines, and tenancy isolation.

Appendix B. Glossary

EMS	Employee Management System; MobiusEMS enterprise workforce platform.
RBAC / ABAC	Role-Based & Attribute-Based Access Control (3-tier sales scoping).
Tenant	Isolated customer boundary in a multi-tenant shared database architecture.
IDOR	Insecure Direct Object Reference; completely blocked by tenant proxy scoping.
Performance Snapshot	Immutable historical record preserving raw inputs, weights, and scores.
Zero-Retention STT	Speech-to-Text pipeline where audio is shredded immediately after transcription.
GIS / GeoNode	Geographic Information System hierarchy (Global → Country → State → Area).

Appendix C. Architecture Review Board & Manager Sign-Off

☒ Product Scope Reconciled: 62 models, 19 route modules, 41 pages, and 54 services fully documented. ☒ Commercial Sales & GIS Subsystem: Restored into architecture, schema, and API specifications. ☒ Multi-Tenancy Invariants Verified: AsyncLocalStorage context and fail-closed Mongoose hooks validated. ☒ Deterministic Math Decoupled: Performance, contribution, attendance, and sales scoring isolated from AI. ☒ Ethical AI Guardrail Approved: Advisory-only boundary enforced in policy and application code. ☒ Zero-Retention Voice Verified: 11 Indian languages supported; ephemeral audio shredded. ☒ Automated Test Suite Passing: 15 test suites and 59 subtests passing with 100% success rate. ☒ Production Operations Ready: Hostinger deployment topology, risk register, and runbooks established.

— END OF TECHNICAL SPECIFICATION (MOBIUSEMS v2.0) —